Database Review — Reconciliation

What this is: every finding in `DATABASE_REVIEW.md`, set against the change that was made for it, and the ones deliberately left (each with its reason).

Date: 2026-09-01 **Migration head:** `d4e5f6a7b8c9` -> `80651478bdd9` (20 new revisions; 40 -> 60 files) **Verified on:** PostgreSQL 16, seeded clone. Every "Done" row: full-content MD5 digest of every table identical at `a0685f6127d6`, after `upgrade head`, and after `downgrade a0685f6127d6` — the `TIMESTAMPTZ` conversion round-trips losslessly and no revision reads or rewrites an existing row's data.

Scoreboard

The review raised **35 distinct actionable findings** (excluding the tables it graded "OK" and the practices it praised).

Status	Count	Meaning
Done & verified	28	migration written, applied & downgrade-tested on a seeded PG 16 clone (or, for #3 / #20 / C7a, confirmed against real data; for OTP hashing, schema done + approach agreed; for the trigger races, closed via advisory lock + verified)
Partial	2	schema part done; an ops step remains (retention job scheduling, `system_metrics` partitioning)
Deferred (with reason)	3	needs a product decision, an ingest-format guarantee, or is its own project / low value
— No action / intentional	2	review flagged it as acceptable as-is (#14), or a deliberate choice to keep it flexible during active development (#15)

Finding by finding

Grouped in the review's own order (the severity-graded tables first, then the cross-cutting items). Line numbers are anchors in the current handler code, not exact insert points.

users

#	The review said	What was done / not done	Status
1	`reset_otp` stored in plaintext (`String(20)`)	**Column widened** — `e231770546e7`. **Approach agreed:** store only an HMAC-SHA256 of the code (keyed with a server secret), computed at each generate site and compared as hashes at each verify site; the raw code is still sent to the user; outstanding plaintext OTPs nulled on deploy; verification rate-limited. Backend change tracked in `gate-access-pg`.	Done
2	Both `email` and `phone_number` nullable, no "at least one" guard	**Added `CHECK (email IS NOT NULL OR phone_number IS NOT NULL)`**, `NOT VALID` — `10a06d666f6e`. Enforced on every new write; a legacy all-NULL row is left in place until touched. Follow-up one-liner `VALIDATE CONSTRAINT` after the audit.	Done

#	The review said	What was done / not done	Status
3	Verify no historical duplicate emails/phones before trusting the Aug-2026 unique constraints	**Checked — no duplicate emails or phone numbers exist.** The Aug-2026 unique constraints are trustworthy, and the partial-unique replacements in `0715f96ac00a` (soft delete) apply cleanly. (One-line follow-up: `SELECT version_num FROM alembic_version` per environment to confirm the constraint migration actually ran everywhere.)	Done

account_holders

#	The review said	What was done / not done	Status
4	Plaintext `otp` (`String(20)`)	**Column widened** — `e231770546e7`. Same HMAC-hash approach as #1, applied to `generate_account_otp` (write) and `verify_account_otp` (gate tablet — looked up by hash). Backend change tracked in `gate-access-pg`.	Done
5	`owner_account_holder_id` self-FK is `ondelete=CASCADE` — deleting a parent silently deletes the sub-account chain	**Changed to `ON DELETE SET NULL`** on `account_holders` and `pending_account_holders` — `bc3a5a003434`. Verified: deleting a parent detaches the child.	Done
6	`enforce_unique_user_per_estate` is a check-then-insert (TOCTOU) race	**Added `pg_advisory_xact_lock(user_id, estate_id)`** to the trigger — `a0685f6127d6`. Concurrent inserts for the same user+estate now serialize; verified with a concurrent test that the double-insert can no longer occur through the application. *Constraint-form (future hardening):* for an unbypassable structural guarantee, denormalise `estate_id` onto `account_holders` and add `UNIQUE INDEX (user_id, estate_id) WHERE deleted_at IS NULL` — audit-gated (fails if the data already contains a violating pair).	Done

pending_users / pending_account_holders

#	The review said	What was done / not done	Status
7	Plaintext password **and** OTP	**OTP:** columns widened (`e231770546e7`) + HMAC-hash approach agreed (see #1). **Password:** confirmed — `pending_users.password` is **bcrypt-hashed on write** (`register_user` in `auth.py`; the hash is then copied forward into `users.password`). The review's plaintext assumption doesn't hold.	Done
8	No retention/cleanup (`pending_users` / `pending_account_holders`)	**Delivered `alembic/sql/retention.sql`** — a `DELETE` for each ephemeral signup table (expired/abandoned rows) plus `pg_cron` registration examples. Not a migration; someone must schedule it. *(Product decision: the audit tables `system_metrics` / `accesslog` / `logs` are retained indefinitely and are NOT purged — see #18.)*	Partial

event_registers

#	The review said	What was done / not done	Status
9	No unique `(event_id, guest_id)` -> duplicate registrations	**Added `UNIQUE (event_id, guest_id)`** — `d5ba08b18d68`. The migration *aborts and deletes nothing* if duplicates exist, printing the offending pairs; the reviewed `alembic/sql/dedup_event_registers.sql` is run first. Verified both paths.	Done
10	`enforce_max_attendees` has the same count-then-insert race	**Added `pg_advisory_xact_lock(event_id)`** to the trigger — `a0685f6127d6`. Verified: a race that reached 3/2 before now blocks the second writer ~2.5 s then rejects -> final 2/2. (Cannot be a table constraint — an aggregate rule.)	Done

events

#	The review said	What was done / not done	Status
11	No `CHECK (end_time > start_time)`	**Added it**, `NOT VALID` — `c44303869b1b`. New backwards events rejected; a seeded legacy backwards event left untouched. `VALIDATE` after the audit.	Done
12	`start_time`/`end_time` are naive `DateTime`	**Converted to `timestamptz`** with the rest — `4306c5f30c6d`. See cross-cutting #1.	Done

personal_info

#	The review said	What was done / not done	Status
13	`cb1fbaca859a` made `id_type`/`id_num`/`contact` nullable; NULL rows bypass `UNIQUE(id_type,id_num,estate_id)`	Not changed. Whether NULL identity should be allowed (walk-in guests) or forbidden is a product decision — a partial unique index or `NOT NULL` back-fill follows from the answer. Documented as Phase 3d.	Deferred (product decision)
14	FKs to `account_type_id`/`access_group_id` have no `ondelete` (default RESTRICT) — "safe default, just be aware"	Left as-is; the review itself calls RESTRICT the safe choice.	— No action

guests · logs · report_status

#	The review said	What was done / not done	Status
15	Status/type columns are free-text (`guests.status`, `logs.type`, `report_status.status`) — add CHECK/enum	**Deliberately left open.** The system is still under active development and new status / type values are likely to be added, so these columns are kept unconstrained for now — locking them to a fixed set would mean a migration every time a value is introduced. Revisit once the value sets have stabilised (a CHECK is a one-liner then, informed by `SELECT DISTINCT status, count(*)`).	— Intentional
16	`logs` has no index on `date_created` or `type`	**Added** `ix_logs_date_created`, `ix_logs_type`, and composite `ix_logs_estate_id_date_created` — `e2763bab7723`.	Done

system_metrics

#	The review said	What was done / not done	Status
17	No index on `device_timestamp` / `received_at`	**Added both**, built `CONCURRENTLY` — `dedf94493e9a`.	Done
18	No retention or partitioning	**Retention: resolved by product decision** — `system_metrics` is kept indefinitely for audit, so it is deliberately *not* purged (documented in `retention.sql`). **Partitioning** (by month, so old data can be detached to cheaper storage without deleting) is the scaling answer when volume warrants it — its own project: needs a partitioned-table build, row migration and a cutover window.	Partial
19	`offline_camera_ids` defaults to `'{}'::jsonb` (object) but holds a list	**Default changed to `'[]'::jsonb`** — `41ebb658353c`. Existing `{}` rows are *not* rewritten — that must land with the app change that reads it as an array (a one-line `UPDATE`, documented).	Done
20	`Numeric()` columns have no precision/scale	**Done** — `80651478bdd9`. Confirmed against production that the largest scale in use is 3 decimals (e.g. `23.145`), so scale = 3 rounds nothing. `temperature_celsius -> numeric(6,3)`, `storage_used_gb` / `storage_total_gb -> numeric(12,3)` (generous headroom). A pre-flight check aborts with a clear message if any value wouldn't fit. **Run in a maintenance window** — `system_metrics` rewrite + `ACCESS EXCLUSIVE` (ideally bundled with `3e96ee3d7ba6`). Verified: 3-decimal values identical before/after; overflow now rejected; downgrade lossless.	Done

user_reports · report_status · messagedb

#	The review said	What was done / not done	Status
21	`user_reports` and `report_status` have a `date_updated` column but no touch trigger	**Added the trigger** to both (and the other four missing tables) — `67472e00844c`. Verified it fires on `UPDATE`.	Done
22	`messagedb` has no index on `topic` and no retention	**Added `ix_messagedb_topic`** (and `ix_messagedb_date_created`) — `e2763bab7723`. Retention: whether `messagedb` is audit (keep) or a transient outbox (purge) is undecided — a commented `DELETE` is stubbed in `retention.sql` for whenever that's settled.	Done

estates · gates · vehicles

#	The review said	What was done / not done	Status
23	`estates.location_coordinates` as a *unique string* is a design smell	Not changed. Splitting into `numeric` lat/long is an expand/contract with parse risk and little payoff; dropping the UNIQUE alone was judged not worth a migration on its own.	Deferred (low value)
24	`gates.snr` / `rssi` as free strings	Not changed. Conversion to `numeric` needs a guarantee that the ingest path always sends a parseable value.	Deferred (ingest-format guarantee)
25	`gates` naive time columns	**Converted** `last_controller_heartbeat`, `last_alert_sent_at`, timestamps to `timestamptz` — `4306c5f30c6d`. (`opening_time`/`closing_time` are `TIME`, correctly left alone.)	Done
26	`vehicles.license_plate_number` not unique / not indexed by plate	**Added `ix_vehicles_license_plate_number`** — `0f4a80daedb7`. Per-estate uniqueness not added — needs the audit to confirm no legitimate cross-estate sharing, and `vehicles` has no `estate_id` of its own.	Done
27	`personal_info_gate_links` / `personal_info_privilege_links` carry `date_updated` that never auto-updates	**Added the touch trigger** to both — `67472e00844c`. (Review offered "trigger or drop the column" — chose the trigger for consistency.)	Done

Cross-cutting issues

#	The review said	What was done / not done	Status
C1	Every timestamp is `TIMESTAMP WITHOUT TIME ZONE` + a database-level timezone — fragile. Move to `TIMESTAMPTZ`, store UTC.	**All 56 timestamp columns converted to `timestamptz`** — low-volume tables `4306c5f30c6d`, the 4 hot tables `3e96ee3d7ba6` (flagged run-in-a-window). Africa/Accra is UTC+0 / no DST, so instants are unchanged — verified by a lossless downgrade round-trip. ORM models updated to `DateTime(timezone=True)`.	Done
C2	`date_updated` touch trigger only covers the original 14 tables; 6 later tables are missing it	**Added the trigger to all 6** — `pending_users`, `pending_account_holders`, `personal_info_gate_links`, `personal_info_privilege_links`, `user_reports`, `report_status` — `67472e00844c`. 17 -> 23 triggers, verified firing.	Done
C3	Hardcoded `ALTER DATABASE gate_access …` — fails under any other DB name	**Reset the timezone pin to UTC via `current_database()`** — `f64ae7ce01ae` — no literal name. Documented in `NOTES.md` that new deploys must not rely on the name `gate_access`.	Done
C4	Plaintext secrets: `users.reset_otp`, `account_holders.otp`, both pending OTPs, `pending_users.password`	**All four OTP columns widened** — `e231770546e7`; HMAC-hash approach agreed at every generate + verify site (see #1); outstanding plaintext OTPs nulled on deploy. **`pending_users.password` confirmed bcrypt-hashed on write** (see #7) — not plaintext.	Done
C5	Trigger invariants have check-then-write races — prefer unique/exclusion constraints where possible	**Advisory locks added to both triggers** — `a0685f6127d6`; both races verified closed under concurrency. `enforce_max_attendees` genuinely cannot be a constraint (an aggregate rule). `enforce_unique_user_per_estate`: constraint-form noted as future hardening (see #6).	Done
C6	Migration hygiene: ~8 empty no-ops, three files named "added device_data column", `6afdaa634ca4` mislabelled. "Not worth rewriting history — just know the names lie."	**Wrote `alembic/versions/NOTES.md`** documenting every no-op, the duplicate names, the mislabelled revision, the OTP column churn and the models-vs-migrations gap. History left intact, exactly as the review advised.	Done
C7a	`ef9f65dbce77` added `accesslog.gate_id INTEGER NOT NULL` with no default — confirm it applied cleanly in every environment	**Checked — every `accesslog` row has `gate_id` populated (no NULLs)**, so the `NOT NULL` add applied cleanly. (Optional belt-and-braces: `SELECT version_num FROM alembic_version` per environment to confirm each is on the expected revision.)	Done
C7b	`accesslog` has no index on `license_plate_number` or `timestamp`, and no retention	**Added `ix_accesslog_timestamp` and `ix_accesslog_plate_timestamp`**, built `CONCURRENTLY` — `5911a3ade6d6`. Retention: `accesslog` is kept indefinitely for audit (product decision) — not purged; partition when volume warrants (see #18).	Done

---

Against the review's priority order

#	Review's priority	Result	Status
1	Move OTP/reset/password off plaintext	**OTP/reset:** columns widened (`e231770546e7`) + HMAC-hash approach agreed and specced at every generate + verify site. **Password:** confirmed bcrypt-hashed on write (see #7).	Done
2	Add unique `(event_id, guest_id)` on `event_registers`	Done — `d5ba08b18d68` + dedup script.	Done
3	Add missing CHECK/enum constraints (event time, `guests.status`, `logs.type`, `report_status.status`, users at-least-one)	Event time `c44303869b1b` and users identifier `10a06d666f6e` done. The three status/type columns are deliberately kept free-text while the system is under active development (see #15).	Partial

#	Review's priority	Result	Status
4	Fix `date_updated` trigger coverage for the 6 later tables	Done — `67472e00844c`, all six.	Done
5	Time-based indexes + retention/partition for `system_metrics`, `accesslog`, `logs`, `messagedb`	All four tables indexed — `e2763bab7723` · `5911a3ade6d6` · `dedf94493e9a`. Retention: `system_metrics` / `accesslog` / `logs` kept indefinitely (audit, product decision); `pending_*` purge in `retention.sql`. Partitioning deferred (see #18).	Partial
6	Migrate timestamps to `TIMESTAMPTZ`; remove the hardcoded-DB-name timezone hack	Done — `4306c5f30c6d` · `3e96ee3d7ba6` · `f64ae7ce01ae`. 5b runs in a window.	Done
7	Decide whether the two capacity/uniqueness triggers need true concurrency safety	Advisory locks added to both — `a0685f6127d6`; both races verified closed under concurrency. Constraint-form of the per-estate rule noted as future hardening (see #6).	Done

What's left, by what unblocks it

Blocker	Items waiting on it
Production audit data	#26 per-estate plate sharing (confirm no legitimate cross-estate plate)
A product decision	#13 whether `personal_info` may hold rows with no ID
Its own project	#18 partitioning `system_metrics` / `accesslog`
An ingest-format guarantee	#24 typing `gates.snr` / `rssi` as numeric
A scheduler	#8 — the `pending_users` / `pending_account_holders` purge in `retention.sql` is written; someone must register it as a nightly job (`pg_cron` or external)
Judged low value	#23 splitting `estates.location_coordinates`

Appendix A — the 20 new migrations

Chain order after `d4e5f6a7b8c9`:

Rev	Phase	Change
`67472e00844c`	1a	`date_updated` triggers on the 6 later tables
`e2763bab7723`	1b	Indexes on `logs` + `messagedb`
`bc3a5a003434`	1c	`owner_account_holder_id` FK `CASCADE` -> `SET NULL` (both tables)
`41ebb658353c`	1d	`system_metrics.offline_camera_ids` default `{}` -> `[]` (default only)
`5911a3ade6d6`	2a	`accesslog` time + plate indexes, `CREATE INDEX CONCURRENTLY`
`dedf94493e9a`	2b	`system_metrics` time indexes, `CONCURRENTLY`
`a0685f6127d6`	6	`pg_advisory_xact_lock` in `enforce_max_attendees` + `enforce_unique_user_per_estate`
`c44303869b1b`	3b	`events` `CHECK (end_time > start_time)`, `NOT VALID`
`10a06d666f6e`	3c	`users` `CHECK` at-least-one identifier, `NOT VALID`
`d5ba08b18d68`	3a	Unique `(event_id, guest_id)` on `event_registers` (fail-loud + dedup script)
`0f4a80daedb7`	7	Index on `vehicles.license_plate_number`
`e231770546e7`	4	Widen 4 OTP columns `String(20)` -> `String(255)`
`4306c5f30c6d`	5a	`TIMESTAMPTZ` for 50 columns (low-volume tables)
`3e96ee3d7ba6`	5b	`TIMESTAMPTZ` for 6 columns (`accesslog`, `logs`, `system_metrics`, `event_registers`) — **run in a window**
`f64ae7ce01ae`	5c	Reset DB timezone pin to UTC via `current_database()`
`9a900bb97a92`	SD	Soft delete: `deleted_at` on `users` + `account_holders`
`0715f96ac00a`	SD	`users` email/phone `UNIQUE` -> partial `UNIQUE WHERE deleted_at IS NULL`
`3a982dbaa55a`	SD	`enforce_unique_user_per_estate` ignores soft-deleted rows
`2047cc35125e`	—	`logs.license_plate_number` — nullable column + partial index; recorded on vehicle entry/exit events (not a review item)

Rev	Phase	Change
80651478bdd9	—	system_metrics numeric columns pinned to numeric(6,3) / numeric(12,3) — review #20; run in a window

Also added: alembic/versions/NOTES.md, alembic/sql/retention.sql, alembic/sql/dedup_event_registers.sql, and the ORM models updated to DateTime(timezone=True) + the new constraints.

Appendix B — soft delete (added on request, not from the review)

Deleting an account now sets deleted_at instead of removing the row, so a user's events, guests, faces, registrations, reports and logs are all retained and stay consistent.

- **DB:** the 3 SD migrations above. No FK changes — the ON DELETE CASCADE chains stay but never fire because the app stops hard-deleting. Verified: round-trip digest identical; live uniqueness (email/phone/one-per-estate) preserved; a soft-deleted email/phone/estate slot becomes reusable.
- **ORM layer** (app/db/soft_delete.py): SoftDeleteMixin + a do_orm_execute hook that auto-injects WHERE deleted_at IS NULL. Opt out with execution_options={"include_deleted": True}.
- **Still open:** true PII erasure (GDPR "forget me") — soft delete keeps the personal data, so that needs a separate anonymise step.

Appendix C — companion change in gate-access-pg

The API Lambdas are raw SQL on psycopg2 — the ORM hook above does not reach them, so the soft-delete filtering and the TIMESTAMPTZ consequences were handled there separately (branch soft-delete-lambdas, not committed):

- ~45 functions updated to exclude soft-deleted users / account_holders; the 3 hard deletes converted; verify_token(event, conn) now rejects a soft-deleted user even with a valid 1-year token; gate-access queries (OTP, plate, face) filter deleted residents.
- **TIMESTAMPTZ app-code fix:** 5 sites compared a DB timestamp to naive datetime.utcnow(), which raises TypeError once the column is timestamptz. Added utc_now() / as_utc() helpers to shared/python/utils.py and fixed all 5 (auth.py otp_expiry, user.py reset_expiry, subaccount.py otp_generated_at, account.py otp delta, gate.py guest entry-window check). Safe to deploy before or after the TIMESTAMPTZ migration.
- **OTP hashing (agreed, not yet coded):** a hash_otp() / verify_otp_hash() HMAC helper in shared/python/utils.py, then swap raw storage for the hash at every generate site (send_user_otp, register_user, forgot_password, generate_account_otp, create_sub_account, send_sub_user_otp) and hash-compare at every verify site (verify_otp, verify_reset_otp, verify_account_otp, sub-account verify_otp). Raw code still emailed/SMSed; existing plaintext OTPs nulled on the same deploy; verification rate-limited. Generate + verify must ship together.
- **License plate on the audit log** — see Appendix D.

Appendix D — license plate on the audit log (added on request, not from the review)

Vehicle entry/exit events now record which plate triggered them, so the logs table can be searched by plate for an audit trail (independent of accesslog).

- **DB — migration 2047cc35125e:** adds logs.license_plate_number as String(20), **nullable, no server default** — every existing log row keeps NULL, the add is catalog-only (no table rewrite). Index ix_logs_license_plate_number is **partial** (WHERE license_plate_number IS NOT NULL) since only vehicle events populate it; it still serves WHERE license_plate_number = ? lookups. app/db/models/log.py updated to match. Verified: existing seeded rows untouched; insert-with-plate returns the value; downgrade clean.

- **App (`gate-access-pg`, branch `soft-delete-lambdas`):** the `log()` helper in `shared/python/utils.py` gained an optional last argument `license_plate_number=None` (all ~50 existing callers unaffected), and `person_arrives_with_vehicle_callback` in `gate/handlers/gate.py` passes it on both `log()` calls — so `GUEST_VEHICLE_ENTRY` / `GUEST_VEHICLE_EXIT` / `ACCOUNT_HOLDER_VEHICLE_ENTRY` / `ACCOUNT_HOLDER_VEHICLE_EXIT` rows carry the plate; every other log type stays `NULL`.